About Me

I spent a total of 6 months from beginning to end (not 100% in the offsec labs) before completing the OSCP cert on my second attempt. Initially I signed up for the course to better hone my skills. I was curious as to how people hacked into larger machines and websites and didn't just run someone else's pre-compiled application. I had knowledge of Windows, Linux, firewalls, networking, and other security topics prior to the course. I also have multiple certifications dealing with other security and network related topics, so I wasn't completely in the dark on the defensive end. For those curious, my certs include: Network+, Security+, CCNA R&S, VMware VCP-DCV, CEH, and most recently the OSCP. But a lot of these, especially the CEH, are "paper certs" and don't truly represent what a candidate or employee knows.

Before signing up for the OSCP certification, I did what everyone else does and read up on what it's like. I found out that it's one of the most hands-on courses which didn't just ask you to choose true or false, but to actually practice and utilize what you learn. I also found a bunch of "my journey" websites. Aside from one or two of those sites, there's just a lack of anything comprehensive out there. As for commands, I would find myself running down a list of them with no real purpose at to why I would use them. There were other times when I forgot to use certain tools when I saw a port open that I was interested in attacking. And then there were the tutorials out there which jumped from step 1 to step 2 to step 7 with little to no explanation of what happened in between. I'm hoping that my OSCP guide, and largely this website, will help you better prepare for your pen testing career.

Course

The OSCP course comes with a minimum 30 day lab. This can be upgraded to 60 or 90 days as well. After the initial purchase, lab time extensions can be purchased with the smallest being 15 days. I had initially purchased 60 days, extended 30, and when I did an exam retake, purchased an additional 15. Unless you have 10 years in the pen testing industry, I highly recommend a minimum of 90 days initially. You're going to see that struggling with some of the boxes for a few days definitely dwindles down your overall time quickly. Know that if the course doesn't teach you something, you won't need to know it. If you're not learning ASLR/DEP buffer overflow bypassing, you won't need to learn it for the exam.

With roughly 650-700 students signing up per month, you get to meet quite a mix of people. Some with professional pen test jobs, some who find it interesting and just want the knowledge, and those who are trying to get into the industry. My recommendation is to find someone that you can talk to either because you know them personally or, like me, met them through the #offsec IRC channel. The mantra for offsec is "Try Harder" and I believe 100% that you should, but don't push yourself to the point that you fear discussion between your peers. It's a fact that group study helps with memory retention. So find yourself a person that will talk

will post a "hint" for that lab. Some are vague and you'll only understand it after you've rooted a box, but some of them will definitely give you that edge you need.

Materials

After signing up you'll receive links for your course materials via email within about 2 weeks. As for the pace of the course material, students are completing the materials between 15 and 25 days. That's assuming you're not someone with a completely open schedule and can spend 12-14hrs per day studying. The course also utilizes a custom-built version of Kali linux. This version has been customized in a way in which you do not (and should not) update the tools or kernel until you've completed your OSCP exam. This means, do not use 'apt-get update/upgrade' and 'apt dist-upgrade'. Should you update, you might find that a newer version of the tools breaks lab compatibility. Instead, what you should do is remove the Keepnote note taking application and install CherryTree. When Keepnote crashes on you and detroys all of your notes, you'll thank me later. Additionally, add the packages 'knockd' and 'sshuttle' which will both come in handy during your labbing.

My strategy when you receive your course materials is to attempt to work through both at the same time. By looking at the video sections, you should be able to determine how far into the reading you should get. Once you've read through a topic, open the video guide and follow along. Anything you don't fully understand from the text will be clarified by watching the videos after. While going through the material, do each and every exercise and takes notes on any that do not specifically state that notes are not required. There are 5 bonus points that you can receive on the exam from your course exercises and lab boxes. Even though you want to rely on your skill, you're going to regret not doing the exercises if you see yourself stuck at 65 points. Those precious points might be the difference between a pass or fail. Again, make sure you do them as you go through the material!

Labs

The labs are open immediately upon receiving your course materials. From a monetary view it sucks losing out on precious lab time but there really isn't a reason to attack the labs if you don't know what you're doing in the first place.

The labs broken up into multiple departments or networks. Only the public dept. will be accessible. Certain public boxes contain a network key that can be used to open up (or revert) other boxes in your control panel. By the end of my total lab time, I finished with a little over 40 boxes rooted, all networks open, and all but one of the hardest boxes owned. While you might be inclined to try to pop all the boxes, it's not needed to pass the exam. While in the labs, do remember to take notes. The 5 bonus points require that 10 labs are written up. Taking clear notes on all boxes will allow you to create your write-up fairly quickly. Remember to also take a screenshot of the IP address and proof.txt file.

relate to that topic. If you just read up on SMB, use nmap to search for ports 139 and 445. Option 2 happens to be the way I had gone through the labs and that's to complete the course material first, then re-review and begin to scan the network.

Exam

The exam is just under 24hrs (23:45). I'm guessing the 15mins you lose is so that the exam machines can be reverted before the next person takes their exam. Exam boxes are put into groups. There's no telling which group you'll get, but it's possible to see the same lab box in another group depending on your number of exam attempts. You should receive an email 5 mins prior to your start time detailing everything you need to get started. Test out your connection and contact support if it doesn't connect. Once your exam starts, all details on which IPs/subnet you're on, number of boxes, point value, and what exactly to submit will be listed in your control panel. The exam is out of a possible 100 points (technically 105 if you root everything and turn in your bonus) with a passing score of 70/100. Each box contains a total number of points that you can receive on it. After talking to a few other OSCPs, we tried calculating the pass rate. What we believe is that it hovers between 18-25%. So only a quarter of everyone taking the exam is going to pass. But as of late, there's been a larger number of people passing. So this figure might have blossomed to 30-40%. As for the number of attempts, I know a lot of people pass on their second attempt, but don't get worried if you don't. An average number of attempts widely ranges from 2-5. It happens but not often that someone passes on their first attempt. I'm pleased to say that I know some individuals who have rooted all exam boxes and gained a perfect score.

The exam is grueling. Don't believe for a second that it's going to be a cake walk. What you can do to help yourself is schedule the exam at a time where you benefit the most. I highly recommend that you book your exam in the afternoon in your timezone (between 1pm-3pm). From what I've seen, students have a higher rate of passing when they can work for a few hours, rest, and begin work again refreshed. When I took the exam, I began around 3pm, stopped at 1am, and rested until 6am. I definitely went to sleep wondering how to get into some of the boxes and having those "ah ha!" moments in the morning where I realized I had forgotten to use a tool or forgot to attempt an attack that I might have learned while in the labs. Don't think for a second that you're going to go the full 24 hours. Your brain doesn't work that way. Take that nap. Take 5 minute breaks every hour. Get up, walk around the block, smoke a cigarette, talk to the girlfriend or wife during that break time. And eat and drink. Have those munchies and coffee ready. Have a plan for the exam boxes. I recommend setting a schedule of 2-3 hours per box before moving on to the next one. The worst thing is to go down a rabbit hole and lose 3-4 hours because of it. Move on, then come back to the box after. You have 24 hours minus some sleep time. Use it wisely. If you feel like you're down a path that dead ends, you're probably right. Re-evaluate what you've done and what tools you've used. Maybe you missed something?

way around the meterpreter restriction is to use a staged payload (windows/shell/reverse_tcp for example) as meterpreter is not directly needed either. Along with the above restrictions you need to make sure that you're submitting the local.txt or proof.txt hash into your control panel, have the correct minimum number of screenshots, and take a screenshot of the local.txt plus IP address and the proof.txt plus IP address. Do not forget any of these!

Even if you don't have enough points to pass, I recommend you send in an exam report as practice. You never know if you'll end up with the same box for the next attempt. When writing my report, I used the template found here: https://www.offensive-security.com/pwk-online/PWKv1-REPORT.doc. I ended up ripping all of section 1 out, entering in my exam notes, while following the format of the template, and renumbering. As for reporting about the boxes, just know that Offsec doesn't need to see 18 pages of your nmap scan output. I've heard of exam reports in the 200-300 page range. In those cases you know they're just copying/pasting their output. It's not uncommon for a report to be as small as 20-30 pages. My recommendation is to keep it within 30-50 pages and with enough detail that an admin reading your report could easily root the box the same way you did.

When making sure you have everything turned in during the exam, please use the following list:

- A minimum number of screenshots as required by the instructions for each box
- At least one screenshot of the local.txt file along with the 'ipconfig', 'ifconfig', or 'ip a' command
- At least one screenshot of the proof.txt file along with the 'ipconfig', 'ifconfig', or 'ip a' command
- Submission of each hash that you find to your control panel dashboard
- Details about each box that you were able to gain a low privilege shell on and details about the privilege escalation. Both need to be written up so that the person grading the exam could easily follow the instructions and replicate the vulnerability
- Meterpreter has been used only once on a box
- Metasploit has been used only once on a box
- Modules other than the approved "auxiliary", "exploit", or "post" have not been used
- Commercial auto-root or auto-vulnerability programs were not used

Bonus Points

I've already mentioned this a little bit, but remember to complete your exercises (where it doesn't explicitly say that you don't have to) and complete the lab report for on 10 boxes. One caviat to the lab report is that both the way in and the privilege escalation need to be unique. Basically, if you rooted two linux boxes using the 'dirty cow' exploit, you need to choose a new

option to connect to your student lab machine. Unfortunately the tool is broken at the moment. The workaround is to replace the Windows 7 ncat. A working version can be found here: https://nmap.org/dist/nmap-7.60-setup.exe

Future

Yup. the rumors are true. As of 7/26/18 Offsec has officially rolled out proctoring to all OSCP students. You can read more here: OSCP Proctoring. Additional details of whether you're subject to proctoring or not can be found here: https://www.offensive-security.com/faq/#proc-1. Most everyone I've talked to is split. While on the one hand it's great to curb cheating. There are those that will take a test for a candidate for roughly $500. There are groups that take the exam together. Chat groups that share answers with each other. So it's natural that Offsec would want to stop that. Then there's the other side that agree that Offsec should implement anti-cheating but is going about it the wrong way.

Reading the FAQ, Offsec is using an application called ScreenConnect. If you haven't had the chance to play with it yet, it's VERY intrusive and this is what everyone is pissed about. I'm sure you've used a free option to connect to a PC before such as Teamviewer or GoToMeeting. You're able to see exactly what the user is doing. If they download a file a dialog box pops up on your side. ScreenConnect acts differently as it can install silently once an initial connection is made. In fact, the caller can install it as a service without the callee knowing and connect back at any time (assuming you don't uninstall it). ScreenConnect also allows the caller to initiate downloads, uploads, commands, and a host of other controls silently. So what stops this proctor from going through all of your files? Nothing. And that's a very large problem.

We already know that the proctors are in the Phillipines. There were multiple job applications and LinkedIn careers available online: https://ph.linkedin.com/jobs/view/manager-exam-proctors-at-offensive-security-592470208. But what's stopping them from doing something outside of their given protocol? You don't get to see them. But they will see you through your webcam, your host PC, and your screen at all times. Maybe you have children. Do you really want some stranger able to watch them, take screenshots, and save those off discreetly, should that child walk by the camera? My suggestion is to install a filewatcher or write a script that monitors when your files are accessed on your host machine. Another option is to created a temporary account with extremely limited access. Whatever you decide, I hope you make the best choice that makes sense to you. And I wish you the best of luck on your proctored exam.

Practice

Thinking of getting your feet wet before jumping into the OSCP course? Are you having to wait a few weeks before your course begins? There are a wide range of practice boxes out there for you to hone your skills on.

techniques. I highly recommend the Kioptrix set to begin with, Vulnix, and PwnOS. Pay close attention to the privilege escalation on both Vulnix and PwnOS.

Hackthebox (free and paid): https://www.hackthebox.eu
This is definitely on the top of my list when someone asks what site they should go to for practice boxes. After you hack the login invitation, you gain access to 20 free lab boxes with an additional 20+ if you pay the VIP membership. I think the monthly price is around $20, so not bad at all. The site contains a lot of modern exploits and boxes which are always constantly being changed and rotated. I believe rotation is on a 2-3 week schedule. Wanna test out the newest exploits such as MS17-010? They've got you covered. Along with pen test boxes the site contains additional challenges such as crypto and reversing.

Fuzzysecurity: http://www.fuzzysecurity.com/tutorials/16.html
I found some of the commands and service escalation helpful but some of it didn't work either. Check out my escalation commands and blackwinterSRV Windows service instead (password: blackwinter).

PwnOS: https://www.youtube.com/watch?v=xL5ZlPQYUMs
This is a tutorial on the PwnOS box by g0tm1lk. I highly recommend taking note of the authorized_keys escalation part of the video.

Overthewire (free): http://overthewire.org/wargames
Some great challenges on this site. New to Linux? Check out the Bandit section to get you started.

I've listed some more sites that you may want to check out. Unfortunately I haven't had a chance to try them. Send me an email letting me know if they're worth it or not.

Practical pen test labs (free and paid): https://practicalpentestlabs.com
Pen tester lab (free and paid): https://pentesterlab.com/exercises
Virtual hacking labs (paid): https://www.virtualhackinglabs.com
CTF365 (paid, 30 day free trial) https://ctf365.com
Root-me (free): https://www.root-me.org
Pwnable.kr (free): http://pwnable.kr

Jump To:

About Me

Course
- Materials
- Labs

Exam
- Bonus Points

Future